

Security remediation report

oss_pages storefront

Generated	2026-09-08 08:10 UTC
Batches in this report	#1, #2
Distinct findings	9
Fixed	9
Still outstanding	0

Provenance

This report does not follow docs/security_audit/secsuite-run-40.pdf. That scan was run against a different codebase: every file it cites is rooted at /Users/johndenvercontaoi/Documents/OSS/frontend/, it reports next 15.0.3 against a pnpm-lock.yaml, and it flags packages (js-cookie, searchkit) and directories (src/, the menu-builder admin, the bbq-design and oko-design component sets) that do not exist in this repository. Its 22 semgrep and 3 gitleaks findings name source files that are not here, so applying them was not possible and reproducing them as if they were would have made this document wrong.

The findings below come from npm audit run against this repository instead, which is the same class of check (dependency CVEs) against the right target. Two items from the original report do still warrant action wherever they live, and are recorded at the end.

Batch 1 -- Dependency vulnerabilities -- no-decision upgrades

Source: npm audit

Before: 9 vulnerabilities (0 critical, 8 high, 1 moderate, 0 low). After: 3 (0 critical, 3 high, 0 moderate, 0 low).

HIGH brace-expansion <=1.1.17 || 3.0.0 - 5.0.8

Transitive dependency - installed: 1.1.15, 5.0.6

Reported

- brace-expansion: DoS via exponential-time expansion of consecutive non-expanding {} groups
CWE-400, CWE-407 - <https://github.com/advisories/GHSA-3jxr-9vmj-r5cp>
- brace-expansion: DoS via unbounded expansion length causing an out-of-memory process crash
CWE-400, CWE-770 - <https://github.com/advisories/GHSA-mh99-v99m-4gvg>
- brace-expansion: DoS via unbounded intermediate arrays, bypassing the CVE-2026-14257 mitigation
CWE-400, CWE-770 - <https://github.com/advisories/GHSA-rgw5-rvv9-x895>

Fixed

npm audit fix -- in-range upgrade, no manifest change. 1.1.15, 5.0.6 -> 1.1.18, 5.0.9
Now installed: 1.1.18, 5.0.9

HIGH browserslist <=4.28.6

Transitive dependency - installed: 4.28.2

Reported

- Browserslist: Unbounded memory growth (no cache eviction) via distinct query results, leading to eventual OOM
CWE-770 - <https://github.com/advisories/GHSA-c83g-rgw3-j3cx>
- Browserslist: Uncaught crash / prototype write via untrusted browserslist-stats.json custom stats (normalizeStats)
CWE-248, CWE-1321 - <https://github.com/advisories/GHSA-73wf-gq98-2v4g>

Fixed

npm audit fix -- in-range upgrade, no manifest change. 4.28.2 -> 4.28.9

Now installed: 4.28.9

HIGH **js-yaml 4.0.0 - 4.3.0**

Transitive dependency - installed: 4.2.0

Reported

- js-yaml: YAML merge-key chains can force quadratic CPU consumption
CWE-400, CWE-407 - <https://github.com/advisories/GHSA-52cp-r559-cp3m>
- JS-YAML: Quadratic CPU consumption in !!omap resolution (3.x and 4.x) -- CVE-2026-59870 fix not backported
CWE-407 - <https://github.com/advisories/GHSA-5p4m-2wfm-xmqj>

Fixed

npm audit fix -- in-range upgrade, no manifest change. 4.2.0 -> 4.3.2

Now installed: 4.3.2

HIGH **nanoid <3.3.18**

Transitive dependency - installed: 3.3.16

Reported

- nanoid: custom generators can loop indefinitely when size is zero
CWE-835 - <https://github.com/advisories/GHSA-2v37-7h3g-55p8>

Fixed

npm audit fix -- in-range upgrade, no manifest change. 3.3.16 -> 3.3.18

Now installed: 3.3.18

MODERATE **qs 2.2.5 - 6.15.3**

Transitive dependency - installed: 6.15.3

Reported

- qs array-limit bypass via bracket-key comma parsing
CWE-770 - <https://github.com/advisories/GHSA-x5fp-wj9c-mxmx>
- qs: Denial of Service via Attacker Controlled isBuffer
CWE-248, CWE-703 - <https://github.com/advisories/GHSA-4mjr-xmp4-gh2g>

Fixed

npm audit fix -- in-range upgrade, no manifest change. 6.15.3 -> 6.16.0

Now installed: 6.16.0

HIGH **undici <=6.27.0 || 7.0.0 - 7.28.0**

Transitive dependency - installed: 6.27.0, 7.28.0

Reported

- undici vulnerable to downstream response desynchronization via retry interceptor
CWE-444 - <https://github.com/advisories/GHSA-8xcm-r25x-g524>
- undici vulnerable to cross-user information disclosure and parse-time crash via degenerate private cache directives
CWE-200, CWE-248, CWE-525 - <https://github.com/advisories/GHSA-4cw7-7wf7-3272>
- undici vulnerable to CRLF Injection via blob-like body 'type' property
CWE-93 - <https://github.com/advisories/GHSA-m8rv-5g2x-5cg5>
- undici vulnerable to cross-user information disclosure via whitespace around equals in Cache-Control directives
CWE-436, CWE-524 - <https://github.com/advisories/GHSA-jr45-8vmc-qm54>
- undici vulnerable to cookie attribute injection via unsanitized domain and unparsed setCookie fields
CWE-74 - <https://github.com/advisories/GHSA-v3r7-h72x-cjcm>

Fixed

npm audit fix -- in-range upgrade, no manifest change. 6.27.0, 7.28.0 -> 6.28.1, 7.29.1

Now installed: 6.28.1, 7.29.1

HIGH next 9.3.4-canary.0 - 16.3.0-preview.10

Direct dependency - installed: 16.2.7

Reported

- Next.js: Middleware / Proxy bypass in App Router applications using Turbopack and single locale
CWE-285 - <https://github.com/advisories/GHSA-6gpp-xcg3-4w24>
- Next.js: Denial of Service in App Router using Server Actions
CWE-834 - <https://github.com/advisories/GHSA-m99w-x7hq-7vfj>
- Next.js: Server-Side Request Forgery in Server Actions on custom servers
CWE-918 - <https://github.com/advisories/GHSA-89xv-2m56-2m9x>
- Next.js: Cache confusion of response bodies for requests with bodies
CWE-524 - <https://github.com/advisories/GHSA-68g3-v927-f742>
- Next.js: Cache confusion of response bodies for requests with bodies containing invalid UTF-8 byte sequences
CWE-116 - <https://github.com/advisories/GHSA-4633-3j49-mh5q>
- Next.js: Unbounded Server Action payload in Edge runtime
CWE-770 - <https://github.com/advisories/GHSA-4c39-4ccg-62r3>
- Next.js: Server-Side Request Forgery in rewrites via attacker-controlled destination hostname
CWE-918 - <https://github.com/advisories/GHSA-p9j2-gv94-2wf4>
- Next.js: Denial of Service in the Image Optimization API using SVGs
CWE-407 - <https://github.com/advisories/GHSA-q8wf-6r8g-63ch>
- Next.js: Unauthenticated disclosure of internal Server Function endpoints
CWE-201 - <https://github.com/advisories/GHSA-955p-x3mx-jcvp>

Deferred

Deferred to batch 2. npm reports the only fix as next@16.3.4, which is outside the stated dependency range in package.json -- a framework upgrade is a decision, not a quick fix.

HIGH postcss <=8.5.22

Direct dependency - installed: 8.4.31, 8.5.20

Reported

- PostCSS has XSS via Unescaped </style> in its CSS Stringify Output
CWE-79 - <https://github.com/advisories/GHSA-qx2v-qp2m-jg93>
- PostCSS: Arbitrary file read and information disclosure via attacker-controlled sourceMappingURL in CSS comments
CWE-22, CWE-200 - <https://github.com/advisories/GHSA-6g55-p6wh-862q>

- PostCSS: incomplete fix of GHSA-6g55-p6wh-862q -- attacker-controlled sourceMappingURL reads arbitrary .map files when `from` is unset

CWE-22, CWE-200 - <https://github.com/advisories/GHSA-fxqj-rqcc-2cmp>

- PostCSS: Path Traversal in Previous Source Map Auto-Loading (sourceMappingURL) leads to Arbitrary .map File Disclosure

CWE-22 - <https://github.com/advisories/GHSA-r28c-9q8g-f849>

Deferred

Deferred to batch 2. npm reports the only fix as next@16.3.4, which is outside the stated dependency range in package.json -- a framework upgrade is a decision, not a quick fix.

HIGH sharp <0.35.0

Transitive dependency - installed: 0.34.5

Reported

- sharp inherited vulnerabilities in libvips: CVE-2026-33327, CVE-2026-33328, CVE-2026-35590, CVE-2026-35591

CWE-1395 - <https://github.com/advisories/GHSA-f88m-g3jw-g9cj>

Deferred

Deferred to batch 2. npm reports the only fix as next@16.3.4, which is outside the stated dependency range in package.json -- a framework upgrade is a decision, not a quick fix.

Batch 2 -- Next.js upgrade -- the deferred decision

Source: npm audit

Before: 3 vulnerabilities (0 critical, 3 high, 0 moderate, 0 low). After: 0 (0 critical, 0 high, 0 moderate, 0 low).

Verification

- tsc --noEmit: clean.
- eslint: 10 errors before the upgrade, 10 after - all pre-existing, none introduced.
- next build: compiles.
- Production server (npm start), 13 routes: home, PLP, PDP, cart, both quote steps, saved-quotes, llms.txt, robots.txt, sitemap.xml and a public PDF all 200.
- Proxy still gates correctly: /admin 404s even with a forged isLoggedIn cookie, and an unknown path 404s. This mattered because one advisory fixed here is a middleware/proxy bypass under Turbopack, and this app relies on proxy.ts.
- PDP configurator prices and adds to cart. The quote Server Action submits, the httpOnly draft cookie survives the redirect, the review page greets by name and the guest lead persists. No page errors.

HIGH next 9.3.4-canary.0 - 16.3.0-preview.10

Direct dependency - installed: 16.2.7

Reported

- Next.js: Middleware / Proxy bypass in App Router applications using Turbopack and single locale

CWE-285 - <https://github.com/advisories/GHSA-6gpp-xcg3-4w24>

- Next.js: Denial of Service in App Router using Server Actions

CWE-834 - <https://github.com/advisories/GHSA-m99w-x7hq-7vfj>

- Next.js: Server-Side Request Forgery in Server Actions on custom servers

CWE-918 - <https://github.com/advisories/GHSA-89xv-2m56-2m9x>

- Next.js: Cache confusion of response bodies for requests with bodies
CWE-524 - <https://github.com/advisories/GHSA-68g3-v927-f742>
- Next.js: Cache confusion of response bodies for requests with bodies containing invalid UTF-8 byte sequences
CWE-116 - <https://github.com/advisories/GHSA-4633-3j49-mh5q>
- Next.js: Unbounded Server Action payload in Edge runtime
CWE-770 - <https://github.com/advisories/GHSA-4c39-4ccg-62r3>
- Next.js: Server-Side Request Forgery in rewrites via attacker-controlled destination hostname
CWE-918 - <https://github.com/advisories/GHSA-p9j2-gv94-2wf4>
- Next.js: Denial of Service in the Image Optimization API using SVGs
CWE-407 - <https://github.com/advisories/GHSA-q8wf-6r8g-63ch>
- Next.js: Unauthenticated disclosure of internal Server Function endpoints
CWE-201 - <https://github.com/advisories/GHSA-955p-x3mx-jcvc>

Fixed

Upgraded next 16.2.7 -> 16.3.4 (npm install next@16.3.4 --save-exact, keeping this project's exact-pin convention). This was the decision batch 1 deferred: npm reported the fix as outside the stated range because package.json pinned 16.2.7 exactly. 16.3.4 is a minor within Next 16, not a major.

Now installed: 16.3.4

HIGH postcss <=8.5.22

Transitive dependency - installed: 8.4.31, 8.5.20

Reported

- PostCSS has XSS via Unescaped </style> in its CSS Stringify Output
CWE-79 - <https://github.com/advisories/GHSA-qx2v-qp2m-jg93>
- PostCSS: Arbitrary file read and information disclosure via attacker-controlled sourceMappingURL in CSS comments
CWE-22, CWE-200 - <https://github.com/advisories/GHSA-6g55-p6wh-862q>
- PostCSS: incomplete fix of GHSA-6g55-p6wh-862q -- attacker-controlled sourceMappingURL reads arbitrary .map files when `from` is unset
CWE-22, CWE-200 - <https://github.com/advisories/GHSA-fxqj-rqcc-2cmp>
- PostCSS: Path Traversal in Previous Source Map Auto-Loading (sourceMappingURL) leads to Arbitrary .map File Disclosure
CWE-22 - <https://github.com/advisories/GHSA-r28c-9q8g-f849>

Fixed

Resolved by the next 16.2.7 -> 16.3.4 upgrade. postcss is pinned by Next's own dependency tree, so it could not move independently -- which is why it was deferred with next rather than fixed in batch 1. 8.4.31, 8.5.20 -> 8.5.23, 8.5.28

Now installed: 8.5.23, 8.5.28

HIGH sharp <0.35.0

Transitive dependency - installed: 0.34.5

Reported

- sharp inherited vulnerabilities in libvips: CVE-2026-33327, CVE-2026-33328, CVE-2026-35590, CVE-2026-35591
CWE-1395 - <https://github.com/advisories/GHSA-f88m-g3jw-g9cj>

Fixed

Resolved by the next 16.2.7 -> 16.3.4 upgrade. sharp is pinned by Next's own dependency tree, so it could not move independently -- which is why it was deferred with next rather than fixed in batch 1. 0.34.5 -> 0.35.4

Now installed: 0.35.4

Carried over from secsuite-run-40.pdf

Two findings in that report are credentials committed to source. The files are not in this repository, but a leaked key is leaked wherever it was committed, and deleting the line does not help because it remains in git history. Both need rotating at the provider, and this repository depends on braintree (^3.38.0), so if that gateway is shared the exposure reaches this app too.

- Braintree private key -- src/app/lib/braintree.js:7
- Elasticsearch API key -- src/pages/api/es/searchkit.js:8 and :43

Reported fix, verbatim: "Rotate the credential, remove it from source, and load from a secret manager."